IPsecIQ — VPN Security Audit Report

AI-Driven IPsec VPN Cryptographic Security & Protocol Assessment Platform
Smart India Hackathon 2026 Internal Evaluation Prototype

Overall Risk Score: 65 / 100	**Qualitative Severity:** HIGH	**Audit Target:** weak_capture
Total Findings: 5	**Critical/High:** 1	**Compliance Baseline:** NIST SP 800-77 / RFC 8221

1. Executive Summary

An automated IPsec VPN security audit was performed on session 'weak_capture'. The deterministic risk assessment engine computed an aggregate risk score of 65/100, classifying the overall security posture as HIGH. A total of 5 security finding(s) were identified across cryptographic, key exchange, and metadata exposure domains.

HIGH RISK PROFILE: Significant deviations from authoritative NIST and RFC standards were identified. The presence of legacy cipher modes, sub-2048-bit Diffie-Hellman groups, or unhardened forward secrecy substantially elevates adversary exploitation potential.

2. Evaluated Threat Matrix

ID	Severity	Risk	Rule ID	Title & Observed Parameter
F001	MEDIUM	+15	CRYPTO_LEGACY_NON_AEAD	**Legacy Non-AEAD Cipher Mode (CBC)** Observed: *encryption = AES-128-CBC*
F002	MEDIUM	+15	DH_GROUP_LEGACY	**Legacy Diffie-Hellman Group (Sub-2048 bit)** Observed: *dh_group = Group 5 (modp1536)*
F003	HIGH	+20	PFS_DISABLED	**Perfect Forward Secrecy (PFS) Disabled** Observed: *pfs = False*
F004	LOW	+10	METADATA_EXPOSURE_FLOW_INFERENCE	**Traffic Analysis & Flow Pattern Exposure** Observed: *esp_packets = 192 packets (38496 bytes)*
F005	LOW	+5	METADATA_EXPOSURE_PLAINTEXT_IKE_HEADERS	**Cleartext IKE Handshake Metadata** Observed: *ike_packets = 6 IKE packets, SPIs: 0x67ceed2b3aeea23f / 0x7b3b7c878b8aaa0d*

3. AI Traffic Inference & Uncertainty Diagnostics

Ensemble Classification:	**Web** (Status: CLASSIFIED)
1D-CNN Temporal Model:	Web
Random Forest Stat Model:	Web
Ensemble Confidence:	98.0%

4. Grounded Standards Evidence (NIST / RFC RAG)

Finding [F001]: Legacy Non-AEAD Cipher Mode (CBC) (+15 pts - MEDIUM)

Observed Parameter: encryption = AES-128-CBC (Source: IKE_SA_INIT Transform Proposal)

Technical Analysis: The IPsec tunnel operates with a non-AEAD legacy cipher mode (encryption = AES-128-CBC). Unlike modern AEAD ciphers (e.g. AES-GCM), CBC mode separates encryption and message authentication. If padding or IV validation is improperly handled in the cryptostack, the tunnel is susceptible to padding-oracle side-channel attacks.

Standards Grounding: *nist_sp800_77_rev1.txt (Section 3.1): "NIST recommends the use of Authenticated Encryption with Associated Data (AEAD) ciphers for all IPsec communications. Advanced Encryption Standard in Galois/Counter Mode (AES-GCM) with 128-bit or 256-bit keys (AES-128-GCM and AES-256-GCM) is strongly recommended for both IKEv2 and ESP payloads. Leg..."*

Remediation Directive: Upgrade encryption suite to an AEAD mode such as AES-256-GCM or AES-128-GCM to ensure atomic confidentiality and authenticity.

Finding [F002]: Legacy Diffie-Hellman Group (Sub-2048 bit) (+15 pts - MEDIUM)

Observed Parameter: dh_group = Group 5 (modp1536) (Source: IKE_SA_INIT Key Exchange (KE) payload)

Technical Analysis: The key exchange negotiation utilized dh_group = Group 5 (modp1536), which provides insufficient mathematical work factor against modern cryptanalytic computing capabilities. Standards mandate at least 2048-bit MODP (Group 14) or 256-bit Elliptic Curve (Group 19).

Standards Grounding: *nist_sp800_77_rev1.txt (Section 3.2): "Key establishment security depends on the mathematical strength of the Diffie-Hellman (DH) group selected during IKE negotiation. Agencies MUST use Diffie-Hellman groups that provide at least 112 bits of equivalent security strength, with 128 bits or higher strongly recommended for sensitive communi..."*

Remediation Directive: Migrate key exchange to Elliptic Curve groups (DH Group 19: ecp256 or Group 20: ecp384) or DH Group 14 (modp2048).

Finding [F003]: Perfect Forward Secrecy (PFS) Disabled (+20 pts - HIGH)

Observed Parameter: pfs = False (Source: Child SA Proposal / Testbed Configuration)

Technical Analysis: Perfect Forward Secrecy (PFS) is disabled on Child SAs. Phase 2 session keys (KEYMAT) are derived directly from the primary IKE SA master key without ephemeral Diffie-Hellman re-computation.

Standards Grounding: *nist_sp800_77_rev1.txt (Section 3.3): "Perfect Forward Secrecy (PFS) ensures that the compromise of long-term gateway private keys or IKE SA master keys does not compromise previously recorded session traffic. When PFS is enabled, an independent ephemeral Diffie-Hellman key exchange is performed during the creation and rekeying of each C..."*

Remediation Directive: Enable Perfect Forward Secrecy (PFS) in the ESP Child SA configuration (e.g., specify esp=aes256gcm16-ecp256!).

Finding [F004]: Traffic Analysis & Flow Pattern Exposure (+10 pts - LOW)

Observed Parameter: esp_packets = 192 packets (38496 bytes) (Source: Outer IP/ESP packet headers and inter-arrival timestamps)

Technical Analysis: ESP encrypted packet sizes, burst frequencies, and inter-arrival intervals are directly observable on the wire (esp_packets = 192 packets (38496 bytes)). Without Traffic Flow Confidentiality (TFC) padding, deep packet inspection and AI ensemble classifiers can infer user application types (Web, Video, VoIP).

Standards Grounding: *nist_sp800_77_rev1.txt (Section 3.5): "To mitigate side-channel traffic analysis where eavesdroppers infer application behavior or data volume from packet sizes and timings, IPsec gateways SHOULD implement Traffic Flow Confidentiality (TFC) padding as specified in RFC 4303. Adding randomized padding masks packet size distributions and re..."*

Remediation Directive: Consider implementing IPsec traffic flow confidentiality (TFC) padding (RFC 4303) to mask packet sizes and timing characteristics.

Finding [F005]: Cleartext IKE Handshake Metadata (+5 pts - LOW)

Observed Parameter: ike_packets = 6 IKE packets, SPIs: 0x67ceed2b3aeea23f / 0x7b3b7c878b8aaa0d (Source: IKE_SA_INIT message headers (UDP 500/4500))

Technical Analysis: ESP encrypted packet sizes, burst frequencies, and inter-arrival intervals are directly observable on the wire (ike_packets = 6 IKE packets, SPIs: 0x67ceed2b3aeea23f / 0x7b3b7c878b8aaa0d). Without Traffic Flow Confidentiality (TFC) padding, deep packet inspection and AI ensemble classifiers can infer user application types (Web, Video, VoIP).

Standards Grounding: *rfc7296_ikev2.txt (Section 1.2): "An IKEv2 communication consists of pairs of request and response messages. The initial exchanges are IKE_SA_INIT and IKE_AUTH. In the IKE_SA_INIT exchange, the peers negotiate cryptographic algorithms via Security Association (SA) proposals, exchange Diffie-Hellman public values in Key Exchange (KE..."*

Remediation Directive: This is an unavoidable architectural aspect of IKEv2 negotiation. Ensure gateway external IP addresses are protected behind border firewalls.

5. Prioritized Remediation Roadmap

• Priority 1: Upgrade encryption suite to an AEAD mode such as AES-256-GCM or AES-128-GCM to ensure atomic confidentiality and authenticity.

• Priority 2: Migrate key exchange to Elliptic Curve groups (DH Group 19: ecp256 or Group 20: ecp384) or DH Group 14 (modp2048).

• Priority 3: Enable Perfect Forward Secrecy (PFS) in the ESP Child SA configuration (e.g., specify esp=aes256gcm16-ecp256!).

• Priority 4: Consider implementing IPsec traffic flow confidentiality (TFC) padding (RFC 4303) to mask packet sizes and timing characteristics.

• Priority 5: This is an unavoidable architectural aspect of IKEv2 negotiation. Ensure gateway external IP addresses are protected behind border firewalls.